Student Name: .....

Theory & Practice of Security – Quizz 2026

Q1: When a browser first accesses a protected resource using **HTTP Basic Authentication**, which HTTP response status code does the server return to request credentials?
A. 200 OK B. 301 Moved Permanently C. 401 Unauthorized D. 403 Forbidden

Q2: Which HTTP header is used by the server to request **Basic authentication**?
A. `Authorization` B. `Authenticate` C. `WWW-Authenticate` D. `Auth-Request`

Q3: In HTTP Basic authentication, the `Authorization` header contains:
A. A hashed password with salt B. un-encrypted username and password
C. An encrypted password using TLS D. A JWT token

Q4: Which statement about **HTTP Basic Auth without HTTPS** is correct?
A. Password is encrypted using RSA B. Password is transmitted in clear text (Base64 only)
C. Password is hashed before transmission D. Password is transmitted via symmetric encryption

Q5: Which operation occurs during the **TLS handshake** but not during the encrypted data phase?
A. Session key generation B. Message authentication
C. Application data transmission D. HTTP request sending

Q6: Which cryptographic technique is primarily used to establish the **shared session key** during TLS handshake?
A. Symmetric encryption only B. Public key cryptography
C. Hash functions D. Digital signatures only

Q7: In modern TLS, the **bulk data encryption** between client and server uses:
A. RSA asymmetric encryption B. AES symmetric encryption
C. Hash functions only D. Elliptic curve signatures only

Q8: What is the main reason TLS switches from asymmetric cryptography to symmetric encryption after the handshake?
A. Compatibility with HTTP B. Faster computation C. Smaller certificates D. Required by browsers

Q9: Which TLS handshake message contains the **server certificate**?
A. ClientHello B. ServerHello C. Certificate D. Finished

Q10: RSA security is primarily based on the computational difficulty of:
A. Discrete logarithm B. Prime factorization C. Elliptic curve D. Hash collision attacks

Q11: Which keys are used in RSA encryption?
A. Private key to encrypt, public key to decrypt B. Public key to encrypt, private key to decrypt
C. Public key only D. Symmetric key only

Q12: In RSA digital signatures:
A. Sender encrypts with receiver public key B. Sender encrypts hash with private key
C. Sender encrypts message with symmetric key D. Sender encrypts message with receiver private key

Q13: A **Man-in-the-Middle attack** occurs when:
A. A server intercepts user traffic B. An attacker intercepts and relays communications between two parties
C. A firewall modifies packets D. A router drops packets

Q14: TLS prevents MITM attacks primarily through:
A. Base64 encoding B. Certificate verification C. DNS resolution D. TCP checksums

Q15: Which condition makes a MITM attack easier?
A. Valid certificate authority verification B. User ignoring browser certificate warnings
C. TLS 1.3 usage D. HSTS enabled

Q16: A **digital certificate** binds which two things?
A. IP address and hostname B. Public key and DNS domain, possibly with alternateSubjectName
C. Public key and DNS domain only (so always trustHostname) D. Hash and encryption key

Q17: What is a **self-signed certificate**?
A. A certificate signed by the browser B. A certificate signed by the same entity whose identity it certifies
C. A certificate signed by a root CA D. A certificate signed by the operating system

Q18: A **certificate chain** exists because:
A. Browsers only store leaf certificates B. Certificates must be renewed every year
C. Trust is delegated from root CAs to intermediate Cas D. TLS requires multiple encryption layers

Q19: A **stack buffer overflow** occurs when:
A. Heap memory is fragmented B. More data is written into a buffer than it can hold
C. CPU registers overflow D. Disk space is exceeded

Q20: Which security technique detects stack corruption by checking a random value before returning from a function?
A. ASLR B. Stack Canary C. NX Bit D. ROP

Q21: The **NX bit** protects against:
A. SQL injection B. Executing code in data memory regions
C. Network attacks D. Privilege escalation

Q22: Return-Oriented Programming (ROP) is an attack technique that:
A. Injects new executable code B. Reuses existing code snippets in memory
C. Exploits SQL databases D. Breaks RSA encryption

Q23: ASLR (Address Space Layout Randomization) defends against exploitation by:
A. Encrypting memory B. Randomizing memory addresses of program components
C. Disabling stack execution D. Checking stack boundaries

Q24: In POSIX permissions, `chmod 750 file` means:

A. Owner: rwx, Group: r-x, Others: --- B. Owner: rw-, Group: r-x, Others: ---
C. Owner: rwx, Group: rwx, Others: --- D. Owner: r-x, Group: r-x, Others: ---

Q25: Which command changes file ownership?
A. chmod B. chgrp C. chown D. setfacl

Q26: The **setuid (S-bit)** on an executable allows:
A. Execution as root always B. Execution with file owner's privileges
C. Execution only by root D. Disabling execution

Q27: Compared to **sudo**, the setuid bit:
A. Is more flexible in privilege management
B. Grants privilege automatically when executing a specific binary
C. Requires password verification every time D. Only works for directories

Q28: Which input is a typical SQL injection payload?
A. `<script>alert(1)</script>` B. `' OR '1'='1` C. `DROP TABLE` (without context) D. `%00`

Q29: Which technique is the **most effective prevention** against SQL injection?
A. Input length validation only B. Prepared statements / parameterized queries
C. Escaping quotes manually D. Encrypting the database

Q30: A **DMZ (Demilitarized Zone)** in network architecture is used to:
A. Replace firewalls B. Isolate public-facing services from internal networks
C. Encrypt traffic between LAN machines D. Store backups

Q31: A **bastion host** is typically:
A. A hardened machine exposed to the internet B. A router
C. A secured DNS server D. A machine used only for backups

Q32: In a **Hub-and-Spoke VPN architecture**:
A. All sites connect directly to each other B. All sites connect through a central hub
C. Only two sites are connected D. No encryption is used

Q33: Which practice is recommended for storing user passwords?
A. Plain text storage B. MD5 hashing
C. Salted password hashing using slow algorithms D. Encrypting passwords with RSA

Q34: Which algorithm is designed for **secure password hashing**?
A. SHA-1 B. MD5 C. bcrypt D. CRC32

Q35: Which is the **best practice for storing application credentials in deployed systems**?
A. Store them in config files B. Store them in KeyVault + still need 1 master password or managed identity
C. Hardcode them in source code D. Store them in environment variables